

Relatório de Testes de Segurança Web ao SITE do meu Agrupamento

1. Introdução

No âmbito da disciplina de Segurança Web, foi realizada uma análise de vulnerabilidades a uma aplicação web utilizando uma ferramenta automatizada de testes de segurança. O objetivo desta tarefa foi identificar possíveis falhas de segurança e compreender o seu impacto.

2. Ferramenta Utilizada

A ferramenta utilizada foi o OWASP ZAP (Zed Attack Proxy), uma aplicação amplamente utilizada para testes de segurança em aplicações web.

3. Aplicação Testada

A análise foi realizada sobre o seguinte alvo:

- Aplicação web pública: <https://home.tomazpelayo.com/agrupamento-de-escolas-tomaz-pelayo-santo-tirso/>

4. Metodologia

Foi utilizado o modo Automated Scan da ferramenta, que permite:

- Exploração automática do website
- Identificação de vulnerabilidades
- Geração de relatórios detalhados

Durante o processo foram recolhidas evidências através de capturas de ecrã e exportação de relatório em formato PDF.

5. Resultados Obtidos

Após a execução do scan, foram identificadas várias vulnerabilidades com diferentes níveis de risco:

- 1 vulnerabilidade de risco elevado (High)
- 6 vulnerabilidades de risco médio (Medium)
- 11 vulnerabilidades de risco baixo (Low)
- 9 informações (Informational)

6. Análise da Vulnerabilidade Crítica

Vulnerabilidade: Vulnerable JS Library

Foi identificada a utilização de uma biblioteca JavaScript desatualizada:

- Biblioteca: pdf.js
- Versão: 2.2.228
- Vulnerabilidade: CVE-2024-4367
- Nível de risco: Alto (High)
- Confiança: Média

Descrição

A biblioteca utilizada apresenta uma vulnerabilidade conhecida que pode ser explorada através do processamento de ficheiros PDF maliciosos.

Possível Exploração

Um atacante pode explorar esta falha da seguinte forma:

1. Criar um ficheiro PDF malicioso
2. Induzir a vítima a abrir esse ficheiro na aplicação
3. A biblioteca vulnerável processa o conteúdo
4. Pode ocorrer execução de código não autorizado ou comportamento inesperado

Impacto

- Execução de código malicioso no browser
- Comprometimento da segurança da aplicação
- Possível acesso a dados sensíveis

Mitigação

- Atualizar a biblioteca para a versão mais recente
- Manter dependências atualizadas
- Monitorizar vulnerabilidades conhecidas (CVE)

Classificação OWASP

Esta vulnerabilidade enquadra-se em:

- OWASP Top 10 A06:2021

7. Conclusão

A análise realizada permitiu identificar diversas vulnerabilidades, destacando-se a utilização de componentes desatualizados como um dos principais riscos.

A utilização de ferramentas como o OWASP ZAP revela-se fundamental para a deteção precoce de falhas de segurança, permitindo a sua correção antes que possam ser exploradas.

A atualização contínua de bibliotecas e boas práticas de desenvolvimento são essenciais para garantir a segurança das aplicações web.

8. Evidências

Foram anexadas as seguintes evidências:

- Captura de ecrã do processo de scan
- Relatório completo exportado em PDF (OWASP ZAP)